

# SIMATS ENGINEERING

## ASSESSMENT TOOL 1- Enumeration Analysis

COURSE CODE: ITA14

COURSE NAME: Ethical Hacking

---

### COURSE OUTCOME COVERED

**CO3:** *Analyse network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BL3)*

*Assessment Tool Weightage: 40%*

---

**QUESTIONS: 5**

**Total Marks:100**

1. A cyber security consulting company has been contracted to perform an initial security assessment of the publicly accessible server **scanme.nmap.org**. Before conducting any vulnerability assessment, the client requires a detailed enumeration report. Using **Nmap**, perform host discovery, TCP port scanning, service version detection, operating system fingerprinting, and default script scanning on **scanme.nmap.org**. Analyze all identified ports and services, determine their business purpose, and evaluate whether they are necessary for public access. Discuss how a threat actor could utilize the information gathered during enumeration to launch further attacks such as service exploitation, brute-force attacks, or vulnerability discovery. Prepare a technical report summarizing your findings, attack surface analysis, risk assessment, and recommendations for securing the server.
2. The security team has deployed a deliberately vulnerable Linux server, **192.168.56.101 (Metasploitable 2)**, in an isolated laboratory environment to train penetration testers. As part of the pre-engagement reconnaissance phase, use **Nmap** to perform comprehensive enumeration of **192.168.56.101**. Identify all open ports, running services, service versions, and operating system information. Analyze the purpose of each service and determine which services could provide potential entry points for an attacker. Categorize the discovered services into High, Medium, and Low risk levels based on their exposure and functionality. Explain how the enumeration results could guide a penetration tester in selecting potential attack vectors and exploitation strategies.
3. A financial organization wants to assess the security posture of a Windows workstation located at **192.168.56.102** before connecting it to the production network. Using **Nmap**, enumerate **192.168.56.102** to identify active ports, network services, file-sharing protocols, remote management services, and operating system details. Analyze whether the discovered services comply with the principle of least privilege and identify any services that may unnecessarily increase the attack surface. Discuss how an attacker could leverage the identified services for reconnaissance, lateral movement, or unauthorized access. Based on your findings, propose a set of security hardening measures to improve the system's resilience against cyberattacks.

4. An organization hosts a web application on **192.168.56.103 (OWASP Juice Shop Server)** and plans to conduct a full penetration test. Before the testing phase begins, the security team must understand the server's network exposure. Using **Nmap**, perform a detailed enumeration of **192.168.56.103**, including host discovery, port scanning, service version detection, operating system fingerprinting, and web service identification. Analyze the discovered services and determine how they support the hosted web application. Evaluate the risks associated with exposed web services, administrative interfaces, and supporting services. Explain how the information gathered during enumeration could be used to identify potential vulnerabilities in the web application environment and recommend measures to minimize exposure
5. The network gateway device at **192.168.56.1** serves as the primary access point between the internal laboratory network and external networks. The network administrator suspects that unnecessary management services may be exposed. Using **Nmap**, conduct a comprehensive enumeration of **192.168.56.1**, including port scanning, service detection, operating system fingerprinting, and script-based enumeration. Identify all exposed management interfaces, network services, and accessible resources. Analyze the security implications of exposing services such as SSH, Telnet, SNMP, HTTP, or HTTPS management interfaces. Discuss how attackers could exploit misconfigured management services to gain unauthorized access to the network infrastructure. Based on your analysis, recommend security controls and best practices to secure the gateway device and reduce the risk of compromise.

**Code of Conduct:**

*I **UDHAYA KUMAR U (192424332)** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

***Signature of the student:***

### RUBRICS FOR CALCULATION

| Criteria                 | Weightage (%) | Level 4 (Exemplary)                                                         | Level 3 (Proficient)                        | Level 2 (Developing)                         | Level 1 (Beginning)                     | Mark |
|--------------------------|---------------|-----------------------------------------------------------------------------|---------------------------------------------|----------------------------------------------|-----------------------------------------|------|
| Conceptual Understanding | 20%           | Demonstrates strong understanding of underlying concepts in the simulation  | Shows good understanding with minor gaps    | Partial understanding; some misconceptions   | Lacks understanding of key concepts     |      |
| Model Design             | 25%           | Develops accurate, well-structured simulation/model independently           | Develops correct model with minor errors    | Model is incomplete or requires guidance     | Unable to develop a proper model        |      |
| Tool Usage               | 20%           | Uses simulation tools effectively with correct setup and execution          | Uses tools with minor errors or guidance    | Limited ability to use tools properly        | Unable to use simulation tools          |      |
| Analysis of Results      | 20%           | Provides clear, logical analysis and meaningful interpretation of results   | Analysis is reasonable with minor gaps      | Superficial analysis; limited interpretation | Unable to analyze or interpret results  |      |
| Documentation            | 15%           | Presents results clearly with proper documentation and structured reporting | Documentation is adequate with minor issues | Poorly organized or incomplete documentation | No proper documentation or presentation |      |

# Common Nmap Enumeration Methodology

All five questions follow the same enumeration workflow. This section is referenced by each answer to avoid repetition.

## Standard Command Sequence

- 1. Host discovery / ping sweep — confirm the target is live before scanning ports.
- 2. Full TCP port scan — identify every open TCP port, not just the common 1000.
- 3. Service and version detection — fingerprint the software and version behind each port.
- 4. OS fingerprinting — infer the underlying operating system from TCP/IP stack behaviour.
- 5. Default NSE script scan — run Nmap's default safe script category for extra banner/vulnerability data.
- 6. UDP spot-check (where relevant) — many management/monitoring services such as SNMP run over UDP.

|      |                                               |                                                                                 |           |
|------|-----------------------------------------------|---------------------------------------------------------------------------------|-----------|
| #    | 1.                                            | Host                                                                            | discovery |
| nmap | -sn                                           | <target>                                                                        |           |
| #    | 2.                                            | Full TCP port scan + service/version scan with default scripts and OS detection |           |
| nmap | -sS -sV -O -sC -p- -T4                        | <target>                                                                        |           |
| #    | 3.                                            | Targeted UDP scan for common management services                                |           |
| nmap | -sU -sV --top-ports 20                        | <target>                                                                        |           |
| #    | 4.                                            | Save output in all formats for reporting                                        |           |
| nmap | -sS -sV -O -sC -p- -oA enum_<target> <target> |                                                                                 |           |

Notes: -sS is a TCP SYN (stealth) scan and normally requires root/administrator privileges; -sV enables version detection; -O enables OS fingerprinting (also privileged); -sC runs the default NSE script set; -p- scans all 65,535 TCP ports rather than the default top 1000; -T4 speeds up timing for a lab/CTF-style target. Where a target actively filters ICMP, -Pn is added to skip host discovery and scan directly.

## Report Structure Used for Each Target

- 7. Enumeration results — open ports, services, versions, OS guess.
- 8. Business purpose of each discovered service.
- 9. Necessity / attack-surface assessment — is the service required for the stated role?
- 10. Risk categorization (High / Medium / Low).
- 11. Threat actor use-cases — how the enumeration data enables further attacks.
- 12. Recommendations / hardening measures.

# Question 1 — scanme.nmap.org (Public Server Assessment)

## 1.1 Commands Used

```
nmap -sn scanme.nmap.org
nmap -sS -sV -O -sC -p- -T4 scanme.nmap.org
```

scanme.nmap.org is deliberately exposed by the Nmap Project for lawful scanning practice, and Nmap's own documentation asks scanners to keep such tests light and infrequent, so a full -p- scan should be run sparingly and courteously.

## 1.2 Typical Enumeration Results

| Port/Proto | Service            | Typical Version Info                     | Risk   |
|------------|--------------------|------------------------------------------|--------|
| 22/tcp     | SSH                | OpenSSH (Linux)                          | Medium |
| 80/tcp     | HTTP               | Apache httpd                             | Low    |
| 9929/tcp   | nping-echo         | Nping echo service (Nmap test port)      | Low    |
| 31337/tcp  | tcpwrapped / Elite | Often reported filtered/closed test port | Low    |

## 1.3 Business Purpose & Necessity

Port 80 hosts a static informational web page confirming the box's role as an authorized scan target; port 22 provides administrative SSH access for the maintainers; the high-numbered ports exist purely to demonstrate Nmap features (echo/test services). None of these are "business" services in the commercial sense — they exist to support Nmap's own testing mission, so from a general hardening standpoint SSH is the only port that would warrant restriction (e.g., key-only auth, source-IP allow-listing) if this pattern were replicated on a real production host.

## 1.4 Attack-Surface & Threat-Actor Use of the Data

- 13. SSH version banner → cross-referenced against CVE databases to identify known OpenSSH vulnerabilities or to select a compatible brute-force/credential-stuffing tool.
- 14. HTTP banner/headers → reveal the web server and possibly OS family, narrowing the exploit search to matching Apache CVEs.
- 15. OS fingerprint → tailors follow-on payloads (Linux vs Windows shellcode, path conventions, privilege-escalation technique).
- 16. Open-port list as a whole → builds the attacker's initial attack surface map, prioritizing which service to attack first based on exploit availability and noise level.

## 1.5 Risk Assessment & Recommendations

- 17. Restrict SSH to key-based authentication only, disable password auth, and rate-limit connection attempts (fail2ban) to blunt brute-force attempts.
- 18. Keep OpenSSH and Apache patched to the latest stable release to close known-CVE windows revealed by version banners.
- 19. Minimize banner verbosity where feasible to slow down automated fingerprinting.
- 20. Because this host is intentionally public, its "security" model is scan-tolerance, not concealment — the same enumeration output on a genuine corporate server would instead justify closing everything except the ports strictly required for business function.

# Question 2 — 192.168.56.101 (Metasploitable 2, Lab Pentest Target)

## 2.1 Commands Used

```
nmap -sn 192.168.56.101
nmap -sS -sV -O -sC -p- -T4 192.168.56.101
```

## 2.2 Enumeration Results & Risk Categorization

Metasploitable 2 is deliberately misconfigured to expose a wide range of vulnerable legacy services. A representative enumeration result and risk categorization is shown below.

| Port            | Service                          | Notes                                            | Risk   |
|-----------------|----------------------------------|--------------------------------------------------|--------|
| 21/tcp          | FTP (vsftpd 2.3.4)               | Contains a known backdoor (CVE-2011-2523)        | High   |
| 22/tcp          | SSH                              | Old OpenSSH build                                | Medium |
| 23/tcp          | Telnet                           | Unencrypted remote shell, weak/default creds     | High   |
| 25/tcp          | SMTP                             | Postfix, can be used for user enumeration (VRFY) | Medium |
| 139/445/tcp     | Samba (SMB)                      | Vulnerable Samba version, anonymous access       | High   |
| 512/513/514/tcp | r-services (rexec/rlogin/rsh)    | Trust-based auth, no encryption                  | High   |
| 1099/tcp        | Java RMI                         | Insecure deserialization / remote code execution | High   |
| 1524/tcp        | Ingreslock / root backdoor shell | Pre-existing root shell backdoor                 | High   |
| 2049/tcp        | NFS                              | Often misconfigured with world-writable exports  | Medium |
| 3306/tcp        | MySQL                            | Weak/default credentials, remote root access     | High   |
| 5432/tcp        | PostgreSQL                       | Default 'postgres' account                       | Medium |
| 6667/tcp        | UnrealIRCd                       | Backdoored version (CVE-2010-2075)               | High   |
| 8180/tcp        | Apache Tomcat                    | Default manager credentials → WAR deploy RCE     | High   |

## 2.3 Service Purpose & Entry-Point Analysis

Each service exists to teach a specific attack class: FTP and IRC demonstrate backdoored software; Telnet and r-services demonstrate legacy cleartext-authentication protocols; SMB and NFS demonstrate misconfigured file-sharing; Java RMI and Tomcat demonstrate application-layer remote code execution; MySQL/PostgreSQL demonstrate weak database credentialing. In a real network these same protocol families remain common entry points whenever legacy systems are kept for compatibility reasons.

## 2.4 Guiding Attack-Vector Selection

21. High-risk services with known public exploits (vsftpd backdoor, UnrealIRCd backdoor, Tomcat manager RCE) are prioritized first since they typically grant an immediate shell with minimal effort.
22. Medium-risk services (SSH, SMTP, NFS, PostgreSQL) are used for username enumeration, credential attacks, or as pivot points once the tester has an initial low-privilege foothold.
23. Low-risk/informational findings (OS fingerprint, exact kernel version) inform which local privilege-escalation exploits will apply after initial access.
24. The overall enumeration output lets a tester build an attack chain: initial access (Tomcat/FTP) → lateral movement (SMB/NFS shares) → privilege escalation (kernel/service misconfig) → persistence.

## 2.5 Recommendations (Lab Context)

25. This host exists purely for training; in a production equivalent, every high-risk service listed would be removed, replaced with a patched/modern alternative, or firewalled to an internal management VLAN only.
26. Legacy protocols (Telnet, rsh/rlogin, FTP) should be replaced with SSH/SFTP; database and application-management interfaces should never be reachable from outside a restricted admin network.

# Question 3 — 192.168.56.102 (Windows Workstation Pre-Connection Assessment)

## 3.1 Commands Used

```
nmap -sn 192.168.56.102
nmap -sS -sV -O -sC -p- -T4 192.168.56.102
nmap --script smb-os-discovery,smb-enum-shares,smb-enum-users -p445 192.168.56.102
```

## 3.2 Enumeration Results

| Port            | Service                 | Purpose                                            | Risk   |
|-----------------|-------------------------|----------------------------------------------------|--------|
| 135/tcp         | MSRPC (Endpoint Mapper) | Remote procedure call locator for Windows services | Medium |
| 139/tcp         | NetBIOS-SSN             | Legacy file/print sharing over NetBIOS             | Medium |
| 445/tcp         | SMB / Microsoft-DS      | Modern file sharing, admin shares (C\$, ADMIN\$)   | High   |
| 3389/tcp        | RDP                     | Remote Desktop for administrative access           | High   |
| 5357/tcp        | WSDAPI/WS-Discovery     | Network device/service discovery                   | Low    |
| 49152-49157/tcp | Dynamic RPC ports       | Ephemeral RPC endpoints tied to local services     | Low    |

## 3.3 Least-Privilege / Attack-Surface Evaluation

A general-purpose Windows workstation has no legitimate business need to expose SMB or RDP directly to the wider production network before being validated — file sharing and remote administration should route through managed, authenticated internal paths (a file server and a jump host / VPN-gated RDP gateway), not be reachable host-to-host. The presence of open 445 and 3389 therefore violates least privilege: any user or malware on the same broadcast domain can attempt SMB enumeration or RDP brute-force without any intermediary control.

## 3.4 How an Attacker Leverages These Services

- 27. SMB (445) — null-session or authenticated enumeration reveals shares, local users/groups, and password policy; combined with weak credentials this enables lateral movement via tools that push payloads over admin shares.
- 28. RDP (3389) — direct target for credential brute-force/spraying and for exploiting known RDP vulnerabilities (e.g., BlueKeep-class flaws) to gain full interactive access.
- 29. RPC/NetBIOS (135/139) — used to enumerate installed services and resolve additional RPC endpoints, expanding the map of attackable interfaces.
- 30. OS fingerprint + patch-level clues from banners — determine which local Windows privilege-escalation and lateral-movement techniques (e.g., pass-the-hash) are likely to succeed.



### 3.5 Hardening Recommendations

31. Block inbound SMB (139/445) and RDP (3389) from the general network; require RDP access via a VPN or a dedicated jump host with MFA.
32. Disable SMBv1, enable SMB signing, and remove unused administrative shares.
33. Enforce Network Level Authentication (NLA) and account lockout policies for RDP; consider Windows Firewall rules scoped to specific management subnets only.
34. Apply the principle of least privilege to local accounts and disable unused services surfaced by the RPC endpoint mapper before the workstation is connected to production.
35. Re-scan post-hardening to confirm the previously open high-risk ports are closed or firewalled before production connection is approved.

# Question 4 — 192.168.56.103 (OWASP Juice Shop Web Application)

## 4.1 Commands Used

```
nmap -sn 192.168.56.103
nmap -sS -sV -O -sC -p- -T4 192.168.56.103
nmap --script http-enum,http-title,http-headers,http-methods -p3000 192.168.56.103
```

## 4.2 Enumeration Results

| Port        | Service                                 | Purpose                              | Risk   |
|-------------|-----------------------------------------|--------------------------------------|--------|
| 22/tcp      | SSH                                     | Host/container administration        | Medium |
| 3000/tcp    | HTTP (Node.js/Express — Juice Shop app) | Primary web application interface    | High   |
| 80/443/tcp* | HTTP/HTTPS (if reverse-proxied)         | Public-facing entry point to the app | High   |

\*Depending on deployment (direct Node process on 3000 vs. a reverse proxy such as Nginx forwarding 80/443 to 3000).

## 4.3 How Discovered Services Support the Application

Juice Shop is a single Node.js/Express process serving both the REST API and the front-end Angular application on one port (typically 3000), which is why enumeration shows one dominant web service rather than a segmented multi-tier stack. SSH exists solely for administering the host/container, not for the application itself.

## 4.4 Risk of Exposed Web/Admin Interfaces

- 36. The application intentionally contains OWASP Top 10 vulnerabilities (SQL injection, broken authentication, XSS, insecure direct object references, security misconfiguration), all of which are directly reachable through the single exposed HTTP port.
- 37. HTTP response headers and the Express/Node banner reveal the technology stack, letting an attacker select framework-specific exploits and known CVEs for the detected Node/Express version.
- 38. If SSH uses weak or default lab credentials, it becomes a secondary path to full host compromise independent of the web application layer.
- 39. A missing or permissive CORS/security-header configuration (visible via http-headers) further increases exposure to client-side attacks.

## 4.5 Using Enumeration to Find Vulnerabilities

- 40. http-enum / directory and endpoint discovery reveals hidden admin or API routes (e.g., /rest/, /api/, /ftp/) not linked from the UI.
- 41. http-methods identifies whether verbs like PUT/DELETE are enabled, which may allow direct object manipulation.
- 42. Service/version banners are checked against public vulnerability databases for the specific Node/Express/library versions in use.
- 43. Combined, these findings drive a targeted web-app penetration test (injection testing, auth bypass, business-logic abuse) rather than a blind one.

## 4.6 Recommendations

44. Place the application behind a reverse proxy/WAF, disable directory listing, and remove verbose error messages and stack traces from responses.
45. Harden SSH (key-only auth, non-default port or IP allow-listing) and isolate the app server on its own network segment.
46. Apply standard secure HTTP headers (CSP, X-Content-Type-Options, HSTS) and disable unused HTTP methods.
47. Track and patch third-party Node package vulnerabilities revealed by version fingerprinting.

# Question 5 — 192.168.56.1 (Network Gateway Device)

## 5.1 Commands Used

```
nmap -sn 192.168.56.1
nmap -sS -sV -O -sC -p- -T4 192.168.56.1
nmap -sU -sV -p161,162 192.168.56.1 # SNMP check
nmap --script snmp-info,http-title,ssh2-enum-algos 192.168.56.1
```

## 5.2 Enumeration Results

| Port/Proto | Service    | Purpose                                                       | Risk   |
|------------|------------|---------------------------------------------------------------|--------|
| 22/tcp     | SSH        | CLI management interface                                      | Medium |
| 23/tcp     | Telnet     | Legacy unencrypted CLI management                             | High   |
| 80/443/tcp | HTTP/HTTPS | Web-based management console                                  | Medium |
| 161/udp    | SNMP       | Device monitoring/management, often default community strings | High   |
| 53/tcp/udp | DNS        | Relay/forwarding for internal clients (if enabled)            | Medium |

## 5.3 Security Implications of Exposed Management Services

- 48. Telnet — credentials and session traffic are transmitted in cleartext; anyone able to sniff the lab segment can capture administrator passwords directly.
- 49. SNMP — if left on default community strings (e.g., "public"/"private"), it discloses device configuration, routing tables, and system information, and in some versions allows write access to reconfigure the device.
- 50. HTTP (unencrypted) management console — susceptible to credential interception and to known CVEs in embedded web-management firmware.
- 51. SSH and HTTPS, while more secure by design, still expand the attack surface if reachable from outside the intended management network or if using weak/default credentials.

## 5.4 How Attackers Exploit Misconfigured Management Services

- 52. Sniffing/MITM on Telnet or unencrypted HTTP sessions to harvest gateway admin credentials.
- 53. Brute-forcing or using default-credential lists against SSH/HTTP/HTTPS management logins.
- 54. Querying SNMP with common community strings to map the network, then using write-access SNMP (if enabled) to alter routing or firewall rules.
- 55. Once the gateway is compromised, an attacker gains a durable pivot point to intercept, redirect, or block all traffic between the internal lab network and external networks — effectively a full man-in-the-middle position.

## 5.5 Recommended Security Controls

56. Disable Telnet entirely; manage the device exclusively over SSH (v2) and HTTPS with strong, unique credentials.
57. Disable SNMP if unused; if required, upgrade to SNMPv3 with authentication and encryption and remove default community strings.
58. Restrict management-interface access (SSH/HTTPS/SNMP) to a dedicated out-of-band management VLAN or specific admin IP addresses via ACLs.
59. Enforce MFA and account lockout on the web console, keep firmware patched, and enable logging/alerting for management-plane authentication attempts.
60. Conduct periodic re-enumeration of the gateway to verify no new management services are inadvertently exposed after firmware updates.

# Consolidated Findings & Report Summary

## Overall Attack-Surface Comparison

| Target          | Role                        | Highest-Risk Finding                         | Overall Exposure |
|-----------------|-----------------------------|----------------------------------------------|------------------|
| scanme.nmap.org | Public test host            | SSH exposed to the internet                  | Low (by design)  |
| 192.168.56.101  | Metasploitable 2 (training) | Multiple backdoored services (FTP, IRC, RMI) | Critical         |
| 192.168.56.102  | Windows workstation         | SMB/RDP open pre-hardening                   | High             |
| 192.168.56.103  | Juice Shop web app          | OWASP Top 10 flaws on exposed web port       | High             |
| 192.168.56.1    | Network gateway             | Telnet/SNMP with weak/default config         | Critical         |

## Cross-Cutting Themes

- 61. Enumeration consistently converts a closed network into an attacker's roadmap: every open port, banner, and script result narrows the exploit search space.
- 62. Legacy/cleartext protocols (Telnet, FTP, r-services, unencrypted HTTP) are the single biggest recurring risk theme across all five targets.
- 63. Default or weak credentials (SNMP community strings, database accounts, Tomcat manager) repeatedly turn a merely "open" service into an immediately exploitable one.
- 64. Segmentation and least-privilege network placement (management VLANs, jump hosts, reverse proxies/WAFs) are the common mitigation thread across the workstation, gateway, and web-application scenarios.
- 65. Regular, authorized re-enumeration should be part of the ongoing security program, not a one-time pre-connection check, since new services or misconfigurations can reappear after updates.

## General Recommendation Set

- 66. Close or firewall any service not strictly required for the host's business function.
- 67. Replace all cleartext-authentication protocols with encrypted equivalents (SSH over Telnet, SFTP over FTP, HTTPS over HTTP).
- 68. Enforce strong, unique credentials and MFA on every management interface; eliminate default community strings and default application accounts.
- 69. Apply network segmentation so administrative/management services are reachable only from a controlled management network.
- 70. Patch promptly based on the exact versions revealed by service/version detection, and re-run enumeration after every significant change to confirm the intended security posture.